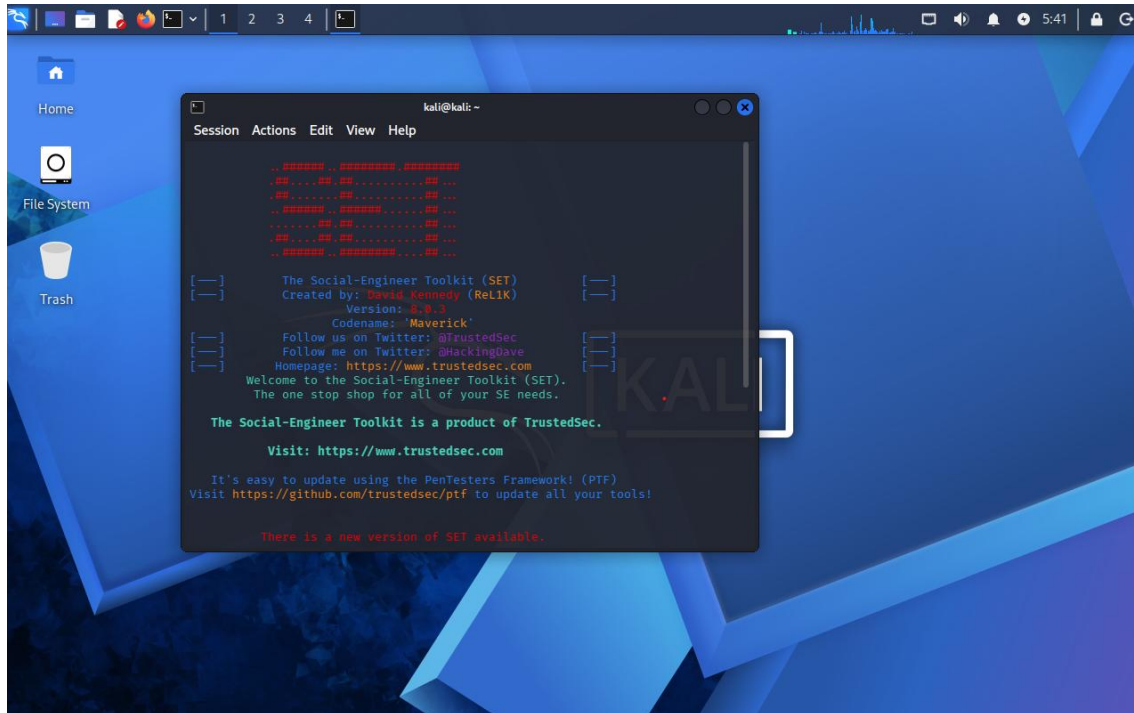


ACTIVIDAD 1.3 PHISING

Rodrigo Hernández Sánchez
2ºDAW Calasanz

1. Documentación del proceso técnico y 2. Configuración correcta del entorno

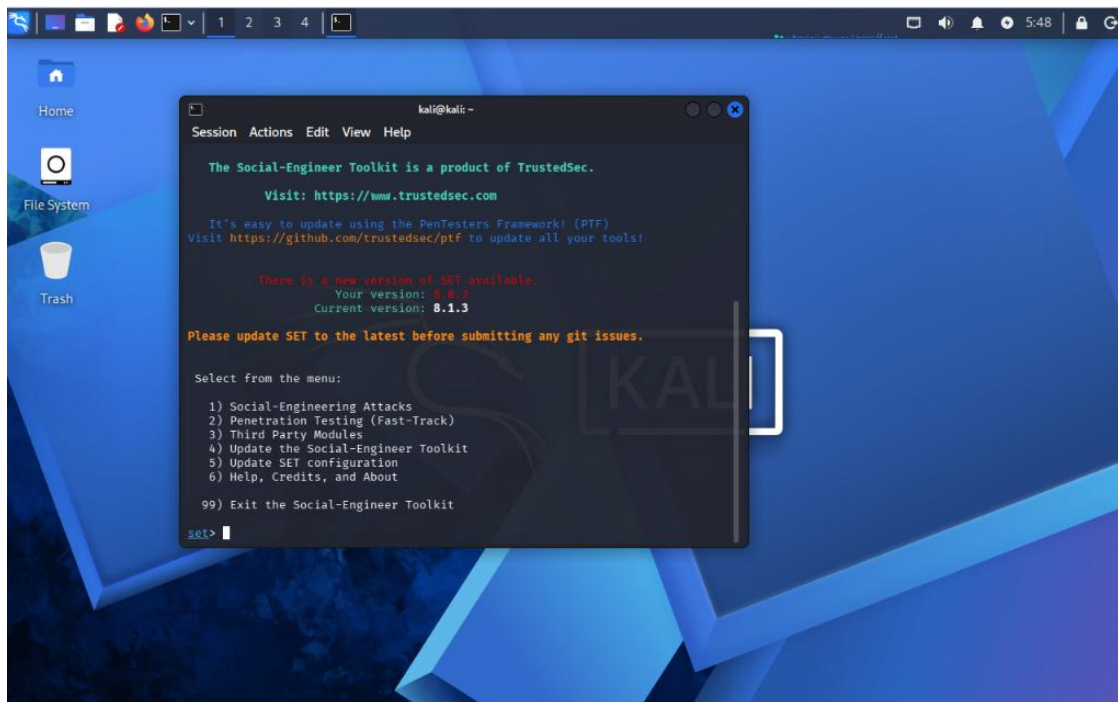
Primero comprobamos que tenemos la herramienta Social Engineer Toolkit instalada, para ellos abrimos la terminal y ejecutamos el comando “sudo setoolkit –version”.



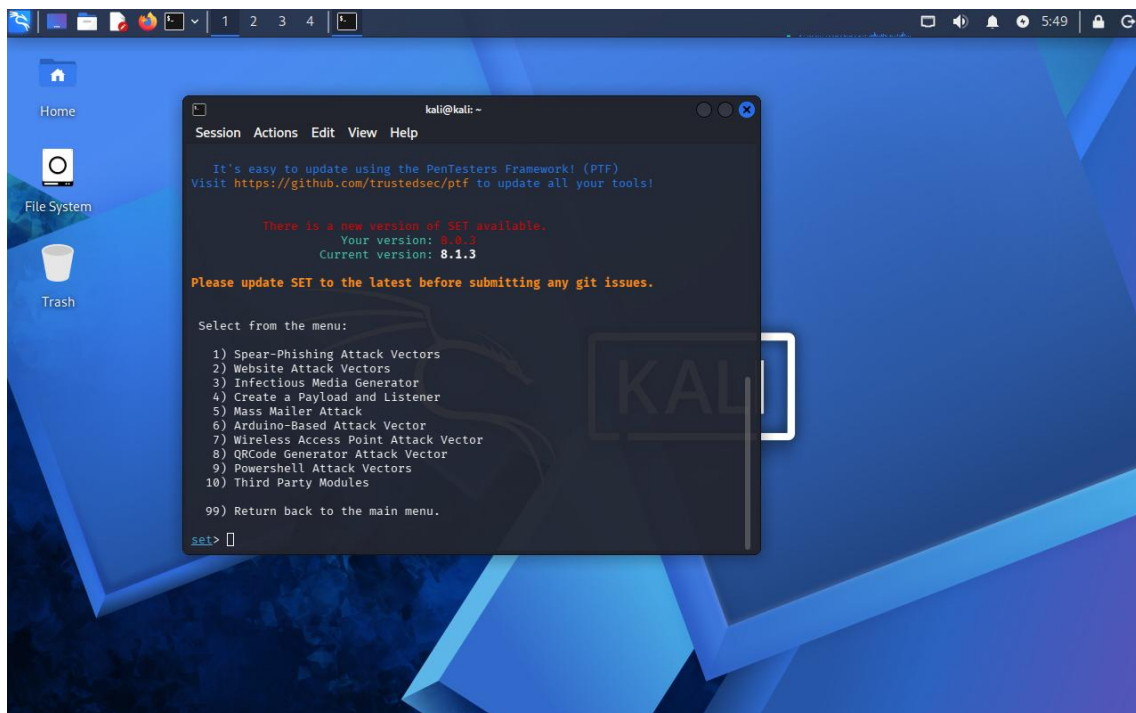
Antes de llegar a esta imagen nos pedirá contraseña la cual será "Kali" y posteriormente aceptar los términos donde tendremos que pulsar "y".

3.Ejecución del ataque de phishing

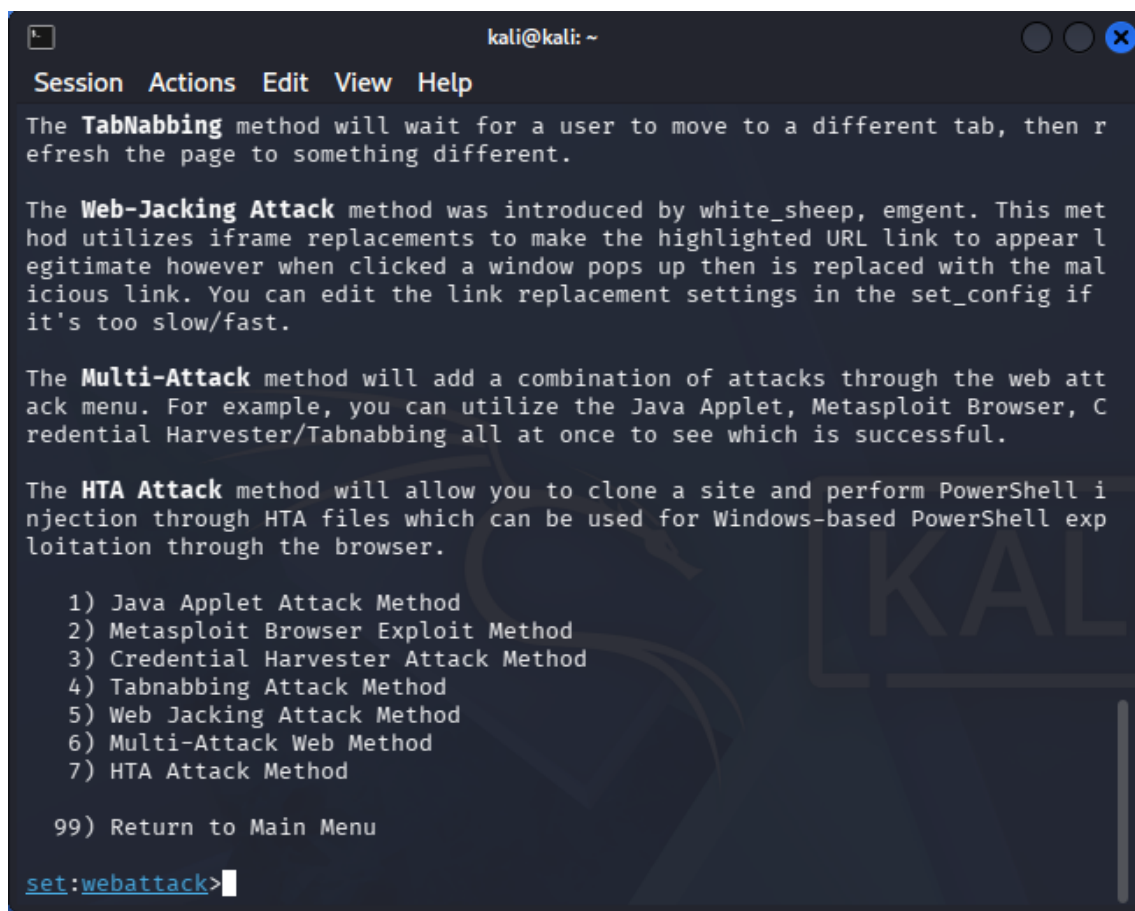
Primero deberemos de iniciar la herramienta SET, para ellos ejecutaremos el comando “sudo setoolkit”. Posteriormente nos saldrá un menú donde deberemos de elegir la herramienta que queremos usar, en nuestro caso usaremos la opción uno del menú.



En el siguiente menú opción dos.



En el siguiente menú opción tres.



A terminal window titled 'kali@kali: ~' showing the SET framework menu. The menu lists several attack methods: 1) Java Applet Attack Method, 2) Metasploit Browser Exploit Method, 3) Credential Harvester Attack Method, 4) Tabnabbing Attack Method, 5) Web Jacking Attack Method, 6) Multi-Attack Web Method, and 7) HTA Attack Method. It also includes an option to return to the main menu (99). The user has entered 'set:webattack>' at the prompt.

```
kali@kali: ~
Session Actions Edit View Help

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

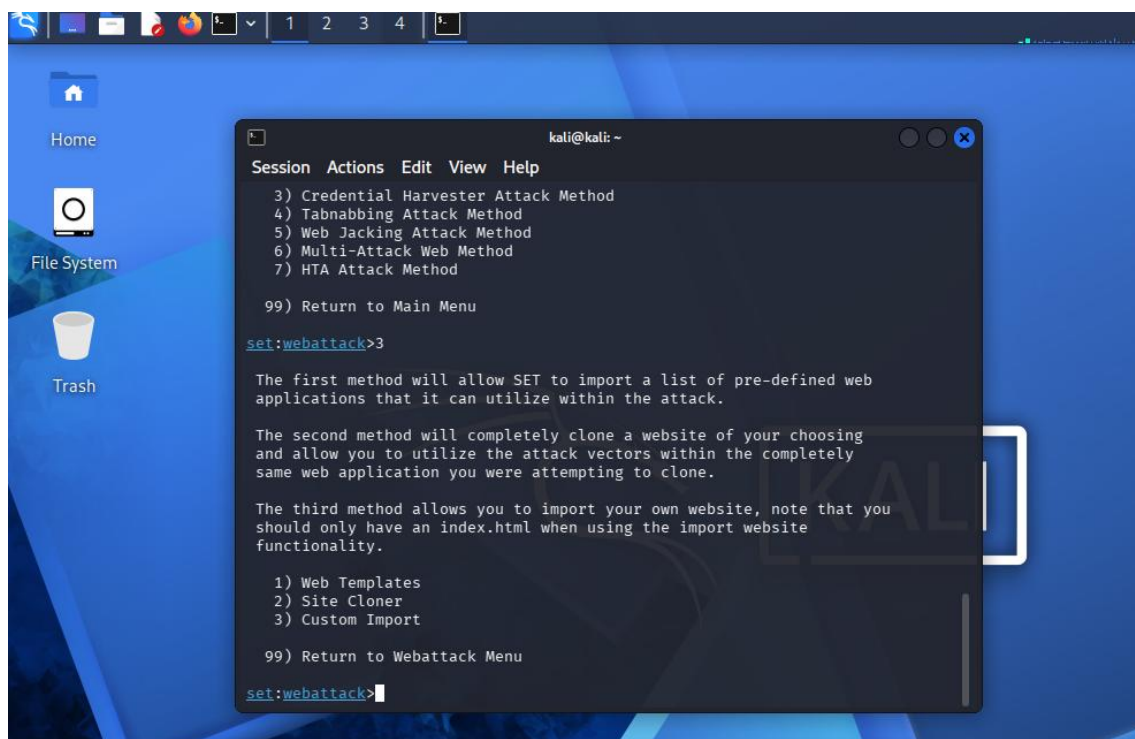
The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>
```

Y por último opción dos.



A screenshot of a Kali Linux desktop with a terminal window open. The terminal shows the SET framework menu with option 3 selected. The menu lists: 3) Credential Harvester Attack Method, 4) Tabnabbing Attack Method, 5) Web Jacking Attack Method, 6) Multi-Attack Web Method, and 7) HTA Attack Method. It also includes an option to return to the main menu (99). The user has entered 'set:webattack>3' at the prompt. The terminal text explains the first method (importing pre-defined web applications) and the second method (cloning a website). It also mentions the third method (importing a custom website) and lists options: 1) Web Templates, 2) Site Cloner, and 3) Custom Import. The user has entered 'set:webattack>' at the prompt.

```
kali@kali: ~
Session Actions Edit View Help

3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

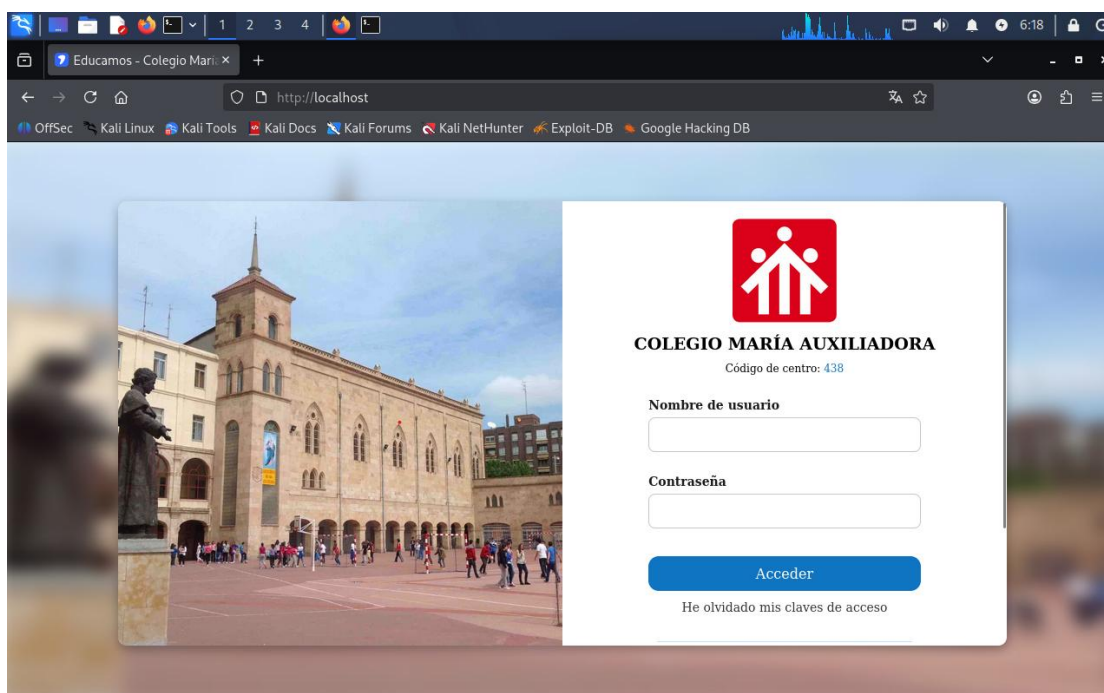
99) Return to Webattack Menu

set:webattack>
```

En el siguiente mensaje que saldrá presionaremos “enter” para usar nuestra IP de nuestra máquina virtual.

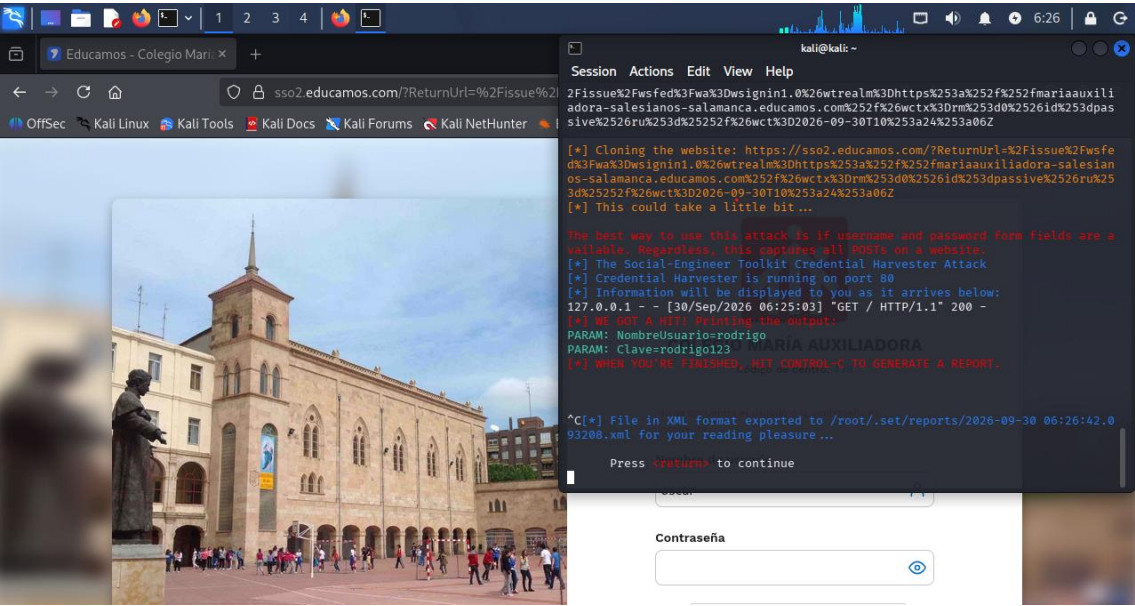
Posteriormente nos pedirá la URL de la pagina a clonar, por lo que deberemos pasársela.

```
kali@kali: ~  
Session Actions Edit View Help  
--  
-- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * --  
--  
The way that this works is by cloning a site and looking for form fields to  
rewrite. If the POST fields are not usual methods for posting forms this  
could fail. If it does, you can always save the HTML, rewrite the forms to  
be standard forms and use the "IMPORT" feature. Additionally, really  
important:  
  
If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL  
IP address below, not your NAT address. Additionally, if you don't know  
basic networking concepts, and you have a private IP address, you will  
need to do port forwarding to your NAT IP address from your external IP  
address. A browser doesn't know how to communicate with a private IP  
address, so if you don't specify an external IP address if you are using  
this from an external perspective, it will not work. This isn't a SET issue  
this is how networking works.  
  
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.1  
5]:  
[-] SET supports both HTTP and HTTPS  
[-] Example: http://www.thisisafakesite.com  
set:webattack> Enter the url to clone: https://www.amazon.es/?&tag=hydesnav-2  
1&ref=pd_sl_781oit2196_e&adgrpid=152290669839&hvpone=&hvptwo=&hvadid=67229136  
2554&hvpos=&hvnetw=&hvrnd=4623666113123095469&hvqmt=e&hvdev=c&hvdvcmdl=&hvl  
ocint=&hvlocphy=1005527&hvtargid=kwd-10573980&hydacr=4855_2227860&mcid=&hvoc  
ijid=4623666113123095469--&hvexpln=nav
```



Después ponemos en el buscador <http://localhost:80> y nos saldrá la página que hemos clonado.

Finalmente, el usuario introduciría el nombre y contraseña y la podríamos capturar.



4. Identificación de vulnerabilidades, 5. Análisis de consecuencias, medidas preventivas y clasificación del ataque y 6. Reflexión ética, uso educativo e indicadores de compromiso.

a. Identifica qué vulnerabilidades explota (técnicas y humanas).

1. Humanas:

- Explotación de la confianza: en este caso el ataque se asienta sobre la tendencia del usuario a confiar en interfaces visualmente familiares (logotipos, tipografía, estructura).

- Mensajes de autoridad o urgencia: se debe a que estos enlaces llegan acompañados de mensajes alarmantes como el de actualizar la cuenta o el de será suspendida, provocando que la víctima actúe sin verificar el origen.

- Falta de conocimientos en el ámbito de la ciberseguridad: Ausencia de hábito y/o conocimientos para inspeccionar la barra de direcciones del navegador o verificar certificados SSL.

2. Técnicas:

- Ausencia de autenticación multifactor (MFA/2FA): en la gran mayoría de casos el servicio clonado solo va a requerir el usuario y contraseña, por lo que darán un acceso total.

- Falta de inspección/validación del Dominio/URL: Los navegadores y filtros web que no detecten la IP/dominio malicioso permiten que el tráfico llegue al servidor donde setoolkit está a la escucha.

- Uso de HTTP sin cifrar: si el sitio cargado corre sobre el puerto 80 sin HTTPS, las credenciales viajan en texto plano (no existe cifrado) por lo que la información será vista por el atacante.

b. Analiza las posibles consecuencias para una víctima real.

- Robo de identidad y suplantación: el atacante puede acceder a la cuenta de la víctima y realizar acciones en su nombre como enviar correos a sus contactos o publicar contenido.

- Pérdida financiera o de datos sensibles: acceso no autorizado a datos bancarios, números de tarjeta o información confidencial.

- Efecto dominó por reutilización de contraseñas: si la víctima utiliza la misma clave en varios servicios, el atacante ganará acceso a todo su entorno digital.

c. Propón al menos 3 medidas preventivas que una persona puede hacer contra ataques de phishing.

- Implementar Autenticación de Doble Factor (MFA / 2FA): configurar métodos de verificación adicionales como aplicaciones de autenticación (Microsoft Authenticator).
- Verificación rigurosa de direcciones URL e indicadores de seguridad: revisar siempre el nombre de dominio en la barra de direcciones antes de ingresar credenciales. Verificar que la URL utilice HTTPS
- Uso de un gestor de contraseñas: los gestores de contraseñas asocian las credenciales guardadas a un dominio específico. Si se está en un sitio clonado en localhost o una IP ajena, el gestor no autocompletará los datos.

d. Clasifica este ataque según su origen (interno/externo) y su alcance (dirigido/masivo). Justifica tu respuesta.

- El ataque es de origen externo debido a que se genera desde un servidor fuera del entorno legítimo de la víctima con el objetivo de engañar al usuario para que se conecte a un puerto específico de la máquina del atacante (VirtualBox).
- El alcance puede ser tanto masivo como dirigido (Spear Phishing) debido a que dependerá de las intenciones del atacante.

En el caso del dirigido el mensaje se personaliza a un perfil específico debiendo de tener información previa sobre el usuario.

En el caso del masivo consiste en enviar mensajes genéricos a cientos de destinatarios para robar datos. Los datos de estos usuarios como el correo o el teléfono son obtenidos de forma ilegal.

e. Explica por qué es importante usar estas técnicas solo con fines educativos.

- Cumplimiento legal: ya que el acceso no autorizado, la clonación ilegítima de sitios con intención de engaño y el robo de credenciales están tipificados como delitos penales.

- Riesgo de daños colaterales: probar estas herramientas en entornos no controlados o sobre usuarios reales sin su consentimiento puede causar pérdida de datos, interrupción de servicios y violaciones de privacidad.

- Enfoque de Seguridad Defensiva: se basa en comprender el mecanismo de ejecución de setoolkit, ya que de esta manera se va a permitir a los profesionales diseñar mejores controles defensivos y educar a los usuarios para mitigar los riesgos de ciberataques reales.

f. ¿Qué señales (indicadores de compromiso) podrían alertar a la víctima, después del ataque, de que sus credenciales ya han sido robadas?

- Sesiones cerradas inesperadamente o alertas de inicio de sesión: una alerta de inicio de sesión va a suponer el recibir correos oficiales del sitio/dominio real notificando accesos desde dispositivos, direcciones IP o ubicaciones geográficas desconocidas.

- Bloqueo de cuenta / Imposibilidad de acceder: en este caso la víctima va a descubrir que su contraseña habitual ya no funciona porque el atacante la ha cambiado tras obtener el acceso.

- Actividad anómala registrada en la cuenta: se basará en mensajes enviados sin conocimiento del usuario o cambios en los ajustes de seguridad.